ETSI TS 103 707 V1.10.1 (2024-12)



Lawful Interception (LI);
Handover Interface for HTTP delivery

Reference
RTS/LI-00273

Keywords
handover, lawful disclosure, lawful interception

ETSI

650 Route des Lucioles
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B
Association à but non lucratif enregistrée à la
Sous-Préfecture de Grasse (06) N° w061004871

Important notice

The present document can be downloaded from the
ETSI Search & Browse Standards application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on ETSI deliver repository.

Users should be aware that the present document may be revised or have its status changed, this information is available in the Milestones listing.

If you find errors in the present document, please send your comments to the relevant service listed under Committee Support Staff.

If you find a security vulnerability in the present document, please report it through our Coordinated Vulnerability Disclosure (CVD) program.

Notice of disclaimer & limitation of liability

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.
No recommendation as to products and services or vendors is made or should be implied.
No representation or warranty is made that this deliverable is technically accurate or sufficient or conforms to any law and/or governmental rule and/or regulation and further, no representation or warranty is made of merchantability or fitness for any particular purpose or against infringement of intellectual property rights.
In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

Copyright Notification

No part may be reproduced or utilized in any form or by any means, electronic or mechanical, including photocopying and microfilm except as authorized by written permission of ETSI.
The content of the PDF version shall not be modified without the written authorization of ETSI.
The copyright and the foregoing restriction extend to reproduction in all media.

© ETSI 2024.
All rights reserved.

Contents

Intellectual Property Rights 5
Foreword 5
Modal verbs terminology 5
Introduction 5
1 Scope 6
2 References 6
2.1 Normative references 6
2.2 Informative references 7
3 Definition of terms, symbols and abbreviations 7
3.1 Terms 7
3.2 Symbols 7
3.3 Abbreviations 7
4 Introductory material 8
4.1 Reference model 8
4.2 Responsibilities 8
5 Basic concepts 9
5.1 General 9
5.2 Delivery 9
5.2.1 General 9
5.2.2 ETSI TS 103 120 Message header 9
5.2.3 ETSI TS 103 120 Object header 10
5.3 Application level header 11
5.3.1 General 11
5.3.2 ApplicationCorrelation 11
5.4 Core parameters 11
5.4.1 General 11
5.4.2 MessagingParty 11
5.4.3 AssociatedBinaryData 12
5.5 Glossary 13
5.6 CSP-defined information 13
5.6.1 General 13
5.6.2 CSP-defined schema 13
5.6.3 Use of common types from ETSI TS 103 280 14
5.6.4 Including binary data in the CSP-defined content 14
5.7 Error reporting 14
6 Transport details 14
6.1 HTTP details 14
6.2 Error reporting for transport 14
7 Security 14
Annex A (informative): Messaging service identifiers 16
A.1 Identifiers 16
Annex B (normative): Messaging XSD definition 17
Annex C (normative): Content delivery 18
C.1 General 18
C.2 Model A 18
C.3 Model B 18

C.4 Model C 19

Annex D (informative): Additional security considerations 20

D.1 Reference model 20

D.2 Summary of considerations 20

D.3 Considerations in more detail 20
D.3.1 Data-at-rest 20
D.3.2 Measures for assuring the Protected Domain 21
D.3.3 Certificate Authorities 21
D.3.4 Collection of data from outside the Protected Domain 21

D.4 Using hashing to obscure sensitive data in audit stores 21
D.4.1 Overview 21
D.4.2 Process 22

Annex E (informative): HTTP Byte Serving (Range Requests) 23

Annex F (informative): Bibliography 25

Annex G (informative): Change history 26

History 27

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the ETSI IPR online database.

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

Foreword

This Technical Specification (TS) has been produced by ETSI Technical Committee Lawful Interception (LI).

Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the ETSI Drafting Rules (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.

Introduction

The present document provides the handover details for HTTP delivery of Lawful Interception (LI) and Lawful Disclosure (LD). For services which are fully standardized (fully and explicitly defined by an existing public standards document), it is recommended that the existing standards definitions are used as the basis of the handover interface. In particular, certain service types have existing LI handover formats and it is recommended to use these where they are applicable, e.g. ETSI TS 102 232-2 [i.5] and ETSI TS 102 232-5 [i.6].

1 Scope

The present document provides the handover details for HTTP delivery of LI and LD. The present document applies in particular to messaging services, but is not limited to messaging services.

The delivery of streaming content is not in the scope of the present document.

2 References

2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the ETSI docbox.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long term validity.

The following referenced documents are necessary for the application of the present document.

[1] ETSI TS 103 120: "Lawful Interception (LI); Interface for warrant information".

[2] Void.

[3] IETF RFC 5246: "The Transport Layer Security (TLS) Protocol Version 1.2".

NOTE: Obsoleted by IETF RFC 8446.

[4] Void.

[5] IETF RFC 8446: "The Transport Layer Security (TLS) Protocol Version 1.3".

[6] IETF RFC 4279: "Pre-Shared Key Ciphersuites for Transport Layer Security (TLS)".

[7] ETSI TS 103 280: "Lawful Interception (LI); Dictionary for common parameters".

[8] IETF RFC 6838: "Media Type Specifications and Registration Procedures".

[9] Void.

[10] IETF RFC 9110: "HTTP Semantics".

[11] IETF RFC 9325: "Recommendations for Secure Use of Transport Layer Security (TLS) and Datagram Transport Layer Security (DTLS)".

[12] IETF RFC 6234: "US Secure Hash Algorithms (SHA and SHA-based HMAC and HKDF)".

[13] IANA: "Hash Function Textual Names".

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are not necessary for the application of the present document, but they assist the user with regard to a particular subject area.

[i.1] Recommendation ITU-T E.164: "The international public telecommunication numbering plan".

[i.2] IETF RFC 5322: "Internet Message Format".

[i.3] IETF RFC 5321: "Simple Mail Transfer Protocol".

[i.4] IETF RFC 3696: "Application Techniques for Checking and Transformation of Names".

[i.5] ETSI TS 102 232-2: "Lawful Interception (LI); Handover Interface and Service-Specific Details (SSD) for IP delivery; Part 2: Service-specific details for messaging services".

[i.6] ETSI TS 102 232-5: "Lawful Interception (LI); Handover Interface and Service-Specific Details (SSD) for IP delivery; Part 5: Service-specific details for IP Multimedia Services".

3 Definition of terms, symbols and abbreviations

3.1 Terms

For the purposes of the present document, the following terms apply:

Lawful Disclosure (LD): process by which a LEA requests and receives data from a CSP

NOTE: A formal definition of Lawful Disclosure (or the related terms "Retained Data" and "Stored Data") is not given in the present document but could be found in relevant applicable regulation.

messaging service: service which allows users to transfer messages to a finite number of users whereby the persons initiating or participating in the communications determine its recipient(s)

3.2 Symbols

Void.

3.3 Abbreviations

For the purposes of the present document, the following abbreviations apply:

CA	Certificate Authority
CSP	Communications Service Provider
HTTP	HyperText Transfer Protocol
HTTPS	HyperText Transfer Protocol Secure
ID	IDentifier
LD	Lawful Disclosure
LDID	Lawful Disclosure IDentifier
LEA	Law Enforcement Agency
LI	Lawful Interception
LIID	Lawful Interception IDentifier
MIME	Multipurpose Internet Mail Extensions

MSISDN	Mobile Station International Subscriber Directory Number
SHA	Secure Hash Algorithm
SSL	Secure Sockets Layer
TC	Technical Committee
TLS	Transport Layer Security
URL	Uniform Resource Locator
UTF	Unicode Transformation Format
UUID	Universally Unique IDentifier
XML	eXtensible Markup Language
XSD	XML Schema Definition

4 Introductory material

4.1 Reference model

This clause provides a Reference Model which applies to request and delivery mechanisms between Law Enforcement Agencies (LEAs) and Communications Service Providers (CSPs) for the present document.

Request means submission of a request for data and delivery means handover of the material that was identified by the CSP as meeting the request. Figure 1 shows the reference model.

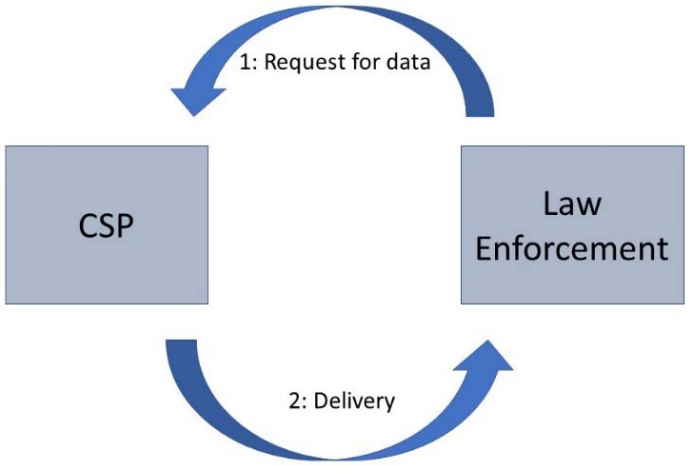


Figure 1: Reference model

The LEA/CSP standards should accommodate for a variety of different law enforcement agencies and for a variety of CSPs. In other words, it is important to support some variance in the internal procedures, processes and data structures. Such variance should not compromise the establishment of security best-practice.

4.2 Responsibilities

The LEA is responsible for creating a lawful request and the request needs to be clear. The LEA delivers the request to the CSP. The legal obligation on the CSP (e.g. what has to be delivered, what has to be retained) is managed independently of the delivery interface and is out of scope of the present document.

The CSP is responsible for the collection of the data within its system, and produces the data using its own capabilities and entirely under the control of the CSP system. The CSP identifies the data which matches the clear request, and only that data. The CSP needs to be able to perform a human review of the request and delivered material. The CSP packages the data, attaches relevant information (e.g. unique reference number, timestamp) and delivers it to the requesting LEA.

Each request is distinct and shall be handled independently of other requests.

5 Basic concepts

5.1 General

The object consists of the following components:

- Application level header (see clause 5.3).
- Core parameters (see clause 5.4).
- Glossary (see clause 5.5).
- CSP-defined information (see clause 5.6).

The components "Core parameters" and "Glossary" vary depending on the service in question. The details are given in clauses 5.4 and 5.5.

The object is delivered using ETSI TS 103 120 [1] as described in clause 5.2.

The following parameter definitions use the terminology of one of the following:

- Mandatory (M): required for every delivery.
- Conditional (C): required in situations where a condition is met (the condition is given in the description).
- Optional (O): provided at the discretion of the implementation.

5.2 Delivery

5.2.1 General

Handover items are delivered using the DeliveryObject as described in ETSI TS 103 120 [1], clause 10. A DeliveryObject may contain either a single handover item (using the "handoverItem" root element) or a collection of handover items (using the "handoverItemCollection" root element). All handover items in a collection shall be related to the same Reference (see table 3).

The present document does not require the use of any of the tasking components from ETSI TS 103 120 [1]. The present document does not require the use of national profiles (as per the definition of profiles in ETSI TS 103 120 [1]).

5.2.2 ETSI TS 103 120 Message header

The Message Header fields shall be populated as defined in ETSI TS 103 120 [1], clause 6.2, with the additional clarifications as shown in table 3.

Table 1: ETSI TS 103 120 [1] Message Header population

Parameter	Description	M/O/C
senderIdentifier	The Sender is the CSP. The SenderIdentifier has two components: a CountryCode and a UniqueIdentifier. They shall be populated as follows: • The CSP shall choose the CountryCode; this may be "XX". • If the LEA has supplied a UniqueIdentifier then this shall be used; otherwise the CSP shall choose its own SenderIdentifier.	M
receiverIdentifier	The Receiver is the LEA. The ReceiverIdentifier has two components: a CountryCode and a UniqueIdentifier. They shall be populated as follows: • CountryCode: If the LEA has supplied a ReceiverIdentifier-CountryCode then this shall be used. It is recommended that this is populated in order to assist with uniqueness, see the text at the end of clause 5.2.3. If no CountryCode has been supplied or agreed with the LEA then "XX" shall be used. • UniqueIdentifier: If the LEA has supplied a ReceiverIdentifier-UniqueIdentifier then this shall be used. In general, the actual LEA should not be identified on this interface, and (unless agreed otherwise) the UniqueIdentifier should contain the text "Not specified".	M
timestamp	Shall specify the time the message was created.	M
version	Shall be set to the version of ETSI TS 103 120 [1] used. If national profiles are not used, the NationalProfileOwner and NationalProfileVersion strings shall be set to "N/A".	M

5.2.3 ETSI TS 103 120 Object header

The payload shall contain a "Delivery Request", which shall contain a DeliveryObject as per ETSI TS 103 120 [1], clause 10.

The common Object fields shall be specified as per ETSI TS 103 120 [1], clause 7.1.1 with the clarifications as shown in table 2.

Table 2: Object top-level fields

Parameter	Description	M/O/C
countryCode	Shall be set to the Country Code used in the ReceiverIdentifier field (see table 1).	M
ownerIdentifier	Shall be set to the value given in the ReceiverIdentifier.	M
nationalHandlingParameters	Shall not be used.	N/A

Parameters for the DeliveryObject shall be set as per ETSI TS 103 120 [1], clause 10, with the clarifications as shown in table 3.

Table 3: Clarifications regarding DeliveryObject as per ETSI TS 103 120 [1], clause 10

Parameter	Description	M/O/C
Reference	Target identifier i.e. LIID or LDID. If an LIID or LDID has been supplied by the LEA then this shall be used. See paragraph at the end of clause 5.2.3. If an LIID or LDID has not been supplied by the LEA then it shall be chosen by the CSP in accordance with practices agreed by LEA and CSP.	M
Manifest	If present, it shall specify ETSI TS 103 707 (the present document) as the delivery type.	O
Delivery	Shall contain an XML-encoded object compliant with the ETSI TS 103 707 (the present document) schema (see clauses 5.3 to 5.6).	M

It is recommended that the LEA chooses the LIID and that specifies a country code for the ReceiverIdentifier-CountryCode as this is one way that can be used to ensure uniqueness of identifiers.

5.3 Application level header

5.3.1 General

Each handover item may contain an application level header, with the fields shown in table 4.

Table 4: Application level Header structure

Parameter	Description	M/O/C
applicationCorrelation	May be used to indicate that a number of handover items are related to each other (see clause 5.3.2).	O

5.3.2 ApplicationCorrelation

If a number of handover items are related to each other, a CSP may use the ApplicationCorrelation structure to indicate that they are related.

When this mechanism is used, related items shall be allocated the same ApplicationLevelID value. This value shall be unique within a given LIID or LDID. The precise format and choice of value is an implementation decision for the CSP.

Each item with the same ApplicationLevelID value shall be allocated a sequence number which is then used to populate the ApplicationSequenceNumber field. The sequence number shall start at zero.

Table 5: ApplicationCorrelation structure

Parameter	Description	M/O/C
applicationLevelID	Application sequence context, unique within a given LIID or LDID. Given as a non-negative integer.	M
applicationSequenceNumber	Zero-based counter within the ApplicationLevelID.	M

5.4 Core parameters

5.4.1 General

Table 6 defines the core parameters of a messaging service.

NOTE: The present document does not contain core parameters for any other services than messaging services.

Table 6: MessagingCoreParameters

Parameter	Description	M/O/C
messageSender	Identifier of the sender of the message, if available. Given as a MessagingParty (see clause 5.4.2).	O
messageReceivers	List of identifiers of the receivers of the message, if available. Given as a list of MessagingParty (see clause 5.4.2).	O
timestamp	Time of the event given as a QualifiedDateTime as per ETSI TS 103 280 [7].	M
associatedBinaryData	List of binary objects (if any) associated with the event (see clause 5.4.3).	O
NOTE: The assumption is that the messaging service is offered as a closed ecosystem, i.e. both parties are subscribed to the same service.		

5.4.2 MessagingParty

The MessagingParty type is used to provide a list of identifiers associated with a messaging party (either a sender or a receiver). Multiple identifiers may be provided. The format and values of the identifiers are determined by the CSP.

Each MessagingParty may include an indication of whether the party was the subject of interception.

Table 7: MessagingParty parameters

Parameter	Description	M/O/C
identifiers	List of one or more identifiers associated with the messaging party, given either as QualifiedPartyIdentifer (see table 7A), where sufficient information is available, or as LongString (see ETSI TS 103 280 [7]).	M
isTargetedParty	Indication that the messaging party is the subject of interception. Absence of the indication may be taken to mean that either the party is not the subject of interception, or that it is not known whether it is the subject of interception.	C

Table 7A: QualifiedPartyIdentifier

Parameter	Description	M/O/C
formatType	Specifies an identifier format for the QualifiedPartyIdentifier value parameter, if available. See clauses 8.2.6.3 and 8.3.5.4 of ETSI TS 103 120 [1] for the FormatType and annex C of ETSI TS 103 120 [1] for the list of identifier formats defined by ETSI. Other definitions may be managed on a national basis.	C
value	Value as LongString (see ETSI TS 103 280 [7]). Additional formatting information is given by the formatType, when present.	M

5.4.3 AssociatedBinaryData

The associatedBinaryData field is used by the CSP to provide details of any data, such as attached images or video, associated with the delivered information. The data itself shall be delivered separately, according to the details in annex C.

The associatedBinaryData field contains a set of binaryObject records, each structured as given in table 8.

Table 8: BinaryObject structure

Parameter	Description	M/O/C
url	URL associated with the delivery of the binary data (see annex C). Shall be unique for a given binary object from a CSP and shall not be re-used by the CSP to identify other binary objects in future.	M
contentLength	Size of the data transferred, given in octets (i.e. equivalent to the Content-Length header in the HTTP transfer), see annex C.	O
contentType	MIME type that described the form of the data (i.e. equivalent to the Content-Type header in the HTTP transfer) if present. Given as per IETF RFC 6838 [8].	O
expiry	Time at which the URL ceases to be valid for delivery of the data (when using Model A delivery, see annex C). Given as QualifiedDateTime as per ETSI TS 103 280 [7].	C
checksum	If used, UTF-8 string containing a checksum of the binary databefore any encryption, compression or other transfer encoding are employed. In version 1.10.1 the ChecksumType field was introduced. New implementations shall use the ChecksumType field and shall support at least "sha-256". If no ChecksumType is provided, the Checksum field shall contain an SHA-256 checksum as per IETF RFC 6234 [12].	O
originalFilename	Original filename associated with the data, if applicable and available.	C
cspDefinedIdentifier	A CSP-defined identifier associated with the data (e.g. as used within the CSP-defined parameters block) if applicable.	C
checksumType	UTF-8 string containing a Hash Function Name as defined in IANA Hash Function Textual Names [13].	C
checksums	A list of one or more ChecksumAndType objects (see table 9). Where more than one checksum type is to be provided for the data, this field shall be used and the checksum field shall not be used.	C

Table 9: ChecksumAndType

Parameter	Description	M/O/C
Checksum	Defined as per checksum in table 8	M
ChecksumType	Defined as per checksumType in table 8	M

5.5 Glossary

The term glossary is used to refer to parameters for which there is a common definition, context and meaning as agreed by LEAs and CSPs.

NOTE: The present document does not contain any glossary parameters.

The use of the glossary is in addition to the technique in clause 5.6 in which the parameter definitions from ETSI TC LI's standard LI dictionary (ETSI TS 103 280 [7]) are re-used.

5.6 CSP-defined information

5.6.1 General

The CSP-defined information includes any self-described information that the CSP can provide for the interception (meta-data and the content of communication) or LD. The parameters themselves are not defined by the present document.

Some examples of items which might be present for messaging services are:

- Time of receiving message.
- Status information - drafted/read/deleted/not consistent.
- Network layer details or hardware ID.
- Group events - joins/leaves/is admin/makes changes to a group.
- Location information.
- Group name.
- Thread title.
- Thread ID.
- Event type.

CSP-defined information shall be provided in the CSPDefinedParameters field.

5.6.2 CSP-defined schema

The CSP is required to describe the schema of data provided in the CSP-defined information and provide appropriate descriptions.

Details of the schema shall be provided using the schemaDetails structure shown in table 10.

Table 10: SchemaDetails structure

Parameter	Description	M/O/C
schemaIdentifier	A unique identifier for the schema assigned by the CSP. If a schema is changed or updated, the CSP shall assign a new schemaIdentifier. The LEA can use the schemaIdentifier to identify the correct schema to interpret the CSP-defined data.	M
schemaURL	Optional URL to indicate where the contents of the schema may be retrieved from.	O
schemaContent	Optional field that the CSP may use to provide the content of the schema as part of the delivery. Alternatively, the schema contents may be provided out-of-band.	O

If the CSP has already provided the schema to the LEA, it may provide only the schemaIdentifier which refers the specific schema previously provided.

5.6.3 Use of common types from ETSI TS 103 280

Where CSP-defined schemas contain information elements which correspond to common types already defined in ETSI TS 103 280 [7] (e.g. MSISDN) CSPs should use the types defined in ETSI TS 103 280 [7] as part of their schema definitions.

NOTE: This technique is in addition to the use of Glossary terms as defined in clause 5.5.

5.6.4 Including binary data in the CSP-defined content

Details for the delivery of binary data associated with a message are given in annex C.

5.7 Error reporting

In the reference model, the request for data and submission of warrant information may not happen on the same logical channel as the delivery of data. Hence, two types of error reporting are required: error reporting related to the transfer and management of warrant information as well as requests for data on the one hand, and error reporting related to the handing over of data by the CSP using the XML/HTTP mechanism specified in the present document on the other hand. Errors related to the latter case are as described in clause 6.2.

6 Transport details

6.1 HTTP details

There shall be a mechanism to establish the destination information as per ETSI TS 103 120 [1], clause 8.3.6 (specifically clause 8.3.6.2). This is not specified in the present document.

The delivery protocol is as specified in ETSI TS 103 120 [1], clause 9, except that the security details (ETSI TS 103 120 [1], clause 9.3.4) are not used and clause 7 of the present document is used.

6.2 Error reporting for transport

Errors relating to the transport mechanism are handled in accordance with the transport mechanism as per ETSI TS 103 120 [1].

7 Security

Implementations shall use HTTPS as defined in IETF RFC 9110 [10].

The TLS version shall be at least 1.2, as defined in IETF RFC 5246 [3]. TLS 1.3 may be supported, as defined in IETF RFC 8446 [5]. TLS implementations shall support mutual authentication through bidirectional certificate usage.

In this regard, TLS 1.2 implementations should support the recommendations given in IETF RFC 9325 [11].

Security requirements shall be mutually agreed for the transport layer, including specification of any necessary encryption, signatures or hash functions and any requirements for encryption of data at rest. In this regard, all implementations should take into account the current state of the art and industry best practices.

Payload security is for further study.

Issues such as certificate management and certificate extensions, key management, key length, key exchange, choice of cryptographic algorithm, etc., are outside of the scope of the present document.

The use of pre-shared keys may be considered for authentication at the transport layer. If this option is selected, the specifications set forth in IETF RFC 4279 [6] shall be followed.

Additional security considerations are given in annex D.

Annex A (informative): Messaging service identifiers

A.1 Identifiers

Annex A identifies three different categories of identifiers of messaging services.

Table A.1: Types of messaging identifiers

Type of identifier	Definition	Example	How it is used
Category 1: Long-term unique ID	This is an identifier that the provider uses for the business purpose of keeping a handle on a single subscriber. It might be internal.	Company specific IDs. Note that these may be unique across different services and linking between identifiers for different services is not necessarily easy.	These are a good basis for submitting and fulfilling a request for information. The identifier may be in a non-public or non-readable format (it may be binary or hex digits) and the present document allows flexibility of formats.
Category 2: Unique but potentially brittle ID	This is an identifier which is likely to be unique at a given point in time but might change over time (e.g. daily/weekly/every few years but not every minute).	Phone number, email address. Note that there are good security reasons for rotating certain identifiers in this category e.g. certain crypto keys which are associated with some IDs.	These are a good basis for making a request provided they have an accurate observed time associated with them (which should not be assumed to be the time of the request). Potentially the provider can then map the brittle identity to their own internal unique ID (i.e. a category 1 identifier). This process (of determining the best possible identifier) may work differently in different situations and is out of scope of the present document.
Category 3: Not unique identity or name	This is an identifier which can be changed or chosen freely and frequently.	A username or informal ID.	These would be useful to be delivered as part of returning information about a subject. It should be noted that there could potentially be many matches to any particular username, even for names that appear to be very rare or unusual.

There is a process which involves discussions between LEA and CSP which needs to result in an identifier to be used as the basis of the authorization. This process is outside of the scope of the present document though it may involve a category 2 identifier and a timestamp to create an agreed identifier (e.g. a category 1 identifier). The conclusion of this process would result in identifiers and the present document lists possible types of identifier where this is necessary for it to be understood. This could be one of a standardized type (phone number, username or user ID, email address) as described in table A.2 or a free-text description.

Table A.2: Parameters and references of messaging identifiers

Identifier	Parameters	Comments or references
User ID	userid	
Username	username or username-and-timestamp	username-and-timestamp is made of username and of timestamp.
Phone number	msisdn or msisdn-and-timestamp, e164-format or e164-format-and-timestamp	msisdn, and e164-format, are defined in the Recommendation ITU-T E.164 [i.1]. msisdn-and-timestamp is made of msisdn and of timestamp. E164-format-and-timestamp is made of e164-format and of timestamp.
Email address	email-address or email-address-and timestamp	IETF RFC 5322 [i.2], IETF RFC 5321 [i.3] and IETF RFC 3696 [i.4] define the email-address. email-address-and-timestamp is made of email-address and of timestamp.

Annex B (normative): Messaging XSD definition

The XSD is provided as an XML XSD schema set, contained in archive ts_103707v011001p0.zip which accompanies the present document.

Annex C (normative): Content delivery

C.1 General

This clause describes the procedures for delivering binary data associated with a DeliveryObject. As described in clause 5.4.3, each DeliveryObject may contain one or more binaryData records. Each record describes a binary object to be delivered from CSP to LEA. Each binary object is delivered using HTTPS following the details in clause 7.

The following models are described in the present document (chosen by mutual agreement):

- Model A: Each binary object is represented by a URL that may be queried by the LEA (see clause C.2).
- Model B: The CSP POSTs each binary object to a URL owned by the LEA (see clause C.3).
- Model C: Each binary object is represented by a URL that may be queried by specifying specific byte-ranges by the LEA (see clause C.4).

Developers should be aware of situations in which there is a mix of very large files and some small files (which could potentially be very urgent). Care should be taken to avoid head-of-line blocking issues i.e. try to share available bandwidth between large and small files thus allowing the small files to be delivered in a timely manner.

C.2 Model A

Each binaryData record contains a URL hosted by the CSP. On receiving the URL, the LEA system may automatically query the URL using the same authentication factors as the original request (see clause 7). The CSP shall then deliver the contents to the LEA using an HTTP Response with the appropriate MIME type.

It is the responsibility of the LEAs to maintain the association between the binary file, the LIID and the particular message (if any).

If a request is made to a valid URL but using the wrong SSL certificate, the CSP shall ensure that the error message returned does not reveal that the URL was valid.

C.3 Model B

The LEA defines a URL scheme for delivery of binary data that can be reached by the CSP. The URL scheme shall contain a single parameter for a unique identifier associated with the binary object:

- https://lea.example.com/binaryData/{*object identifier*}/

The LEA shares the scheme with the CSP in advance. When delivering binary data, the CSP forms a complete URL for each binary object by allocating a UUID to it and inserting it into the appropriate part of the URL scheme. The CSP uses this URL to populate the URL field in the binaryData record for that object.

The CSP shall deliver the binary data after delivering the DeliveryObject containing the binaryData record. The CSP delivers the data by HTTP POST to the appropriate URL using the appropriate MIME type. The CSP client shall use the Expect request header field to expect a 100 CONTINUE response from the LEA server. If the size of a file is known ahead of time, it shall be added to the HTTP message's Content-Length header. It is recommended that the CSP's client continue timeout be set according to the expiry time given in the binaryData record (see table 8), and that the timeout should be sufficient to allow the DeliveryObject to be processed by the LEA before the binary data is transferred.

The LEA is responsible for maintaining the association between the binary data, the LIID and the message by using the URL. LEA implementations should provide for the possibility that the DeliveryObject is processed after an attempt to deliver binary content is made.

C.4 Model C

Model C may be used if agreed by both the LEA and CSP.

The process starts the same as Model A up to the stage where the LEA retrieves a DeliveryObject. At that stage, the LEA shall choose which delivery model is appropriate for the type and size of data specified in the DeliveryObject.

They should consider their known constraints or limitations for retrieving data as described in the DeliveryObject.

If the LEA chooses Model C, it shall submit one or more Range Requests to specify the portion of the binaryData to be retrieved. This process continues for all desired ranges, up to and including the entire binaryData object.

It is the responsibility of the LEAs to maintain the association between the binary file, the LIID, the data ranges being retrieved, and the reassembly of the binary file.

Annex D (informative): Additional security considerations

D.1 Reference model

The reference model in figure D.1 is used for this annex.

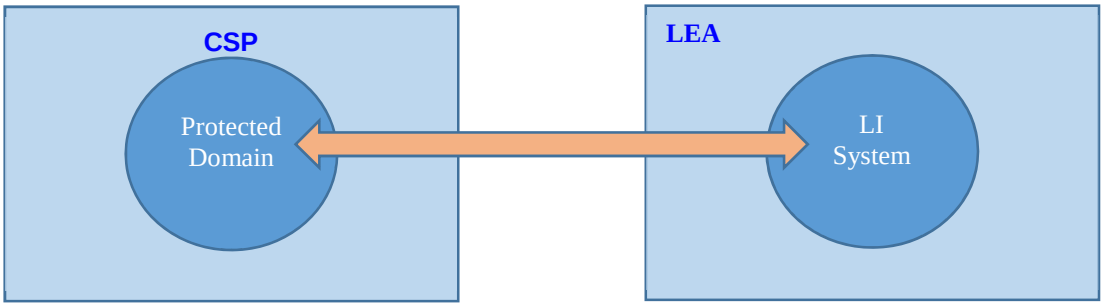


Figure D.1: Reference model showing Protected Domain

This annex considers the provision of security via the isolation of a Protected Domain within the CSP. This domain or enclave is used for providing LEA support within the CSP.

D.2 Summary of considerations

Each CSP is different and has different concerns and designs so the present document does not put forward a one-size-fits-all solution. However, there are important considerations which are relevant to most or all situations; the approach of the present document is to provide a list of these security considerations. CSPs should take these into account and should try to provide reassurance to LEAs on relevant considerations.

D.3 Considerations in more detail

D.3.1 Data-at-rest

Sensitive data is being stored by the CSP in two stages:

a) While a task is active/while a query is being answered. During an active task, there is sensitive data present (e.g. in order to match against target identifiers). Care should be taken to keep these within the Protected Domain except where necessary (see clause D.3.4).

b) After a task or query has been completed, e.g. for audit purposes. It is important to give careful consideration to audit data. Where data is stored for long periods of time (e.g. years) then it is particularly important to avoid keeping large stores of sensitive data. A useful technique is to hash or obscure those fields which are particularly sensitive (typically it will be the personally identifiable information e.g. the target identifier). A process for obscuring sensitive fields is given in clause D.4. This allows most fields to remain and provides a process for the CSPs to re-instate the sensitive fields where necessary (but not on a blanket or ad hoc basis).

D.3.2 Measures for assuring the Protected Domain

The following considerations are relevant for assuring the Protected Domain:

a) How is the Protected Domain defined? It is important to look at how the boundary of the Protected Domain is created and enforced. Where practical, then it is helpful for there to be some sort of physical separation but the concerns around "following the sun" (see also point b) apply. There should be software boundaries and isolation to restrict access so that data within the Protected Domain is only seen by those with authority to do so.

b) People. Consideration should be given to the process by which people are given privileges to work within the Protected Domain. It is important to consider that many CSP operations have to work 24/7 and potentially "follow the sun" so consideration should be given to the situation where staff in the Protected Domain come from a variety of nationalities.

c) Data leaving the Protected Domain. It is important to look at any data that might potentially leave the Protected Domain. Consideration should be given to alarms, logs and backups. Wherever possible, care should be taken to ensure that alarms, logs and backups do not contain sensitive information. If it is necessary that these do contain sensitive information, then they should not leave the Protected Domain. Audit logs should also be considered: see clause D.3.1.

d) Protective monitoring should be considered in line with industry best practice. Specific examples relating to Protected Domains include the monitoring of:

   - When people are assigned to (or removed from) the privileges within the Protected Domain.
   - Access to sensitive data stores within the Protected Domain.
   - Account behaviour for people who have privileges within the Protected Domain.

D.3.3 Certificate Authorities

Certificate Authorities (CAs) are used to help identify where the data came from i.e. clear assurance that data came from the relevant CSP. Consideration should be given to whether a CA can help give assurance that the data came from within the Protected Domain.

D.3.4 Collection of data from outside the Protected Domain

Data collection is typically taking place on systems outside the Protected Domain. The following considerations apply to data that is collected from outside the Protected Domain:

- The footprint of this collection process should be as small as possible.
- Specifically look at audit logs and error/alarm procedures. They should either not have sensitive information or should be passed to systems within the Protected Domain.

D.4 Using hashing to obscure sensitive data in audit stores

D.4.1 Overview

This clause provides a solution to meet two important considerations:

1) CSPs should keep audit records so that all necessary data fields can be checked when needed.

2) To protect LEA operations and subscribers' privacy, the CSPs should not store sensitive personal information for longer than is necessary.

The present document does not define the meaning of the word "necessary" in either point (1) or point (2). The purpose of this clause is to provide a technique that facilitates audit and also reduces the storage of sensitive information.

D.4.2 Process

The process is based on the following situation:

- That there is sensitive information (e.g. a selector used to identify a subject of interest) which is part of the tasking/request to the CSP.
- That the CSP wants to be able to check or audit this information after the request/tasking has been completed.
- That there is a concern about the CSP keeping a large store of sensitive information.

The following process is designed to be useful for the above situation:

- The LEA generates the sensitive field as part of the tasking/warrant/requesting process.
- The LEA also generates a random value (called a salt).
- The LEA also generates a hash based on the sensitive field and the salt.
- The LEA sends the sensitive field, salt and hash to the CSP.
- The CSP checks that the hash has been properly created (i.e. that it is the hash of the sensitive field and the salt).
- Once the request has been fulfilled (i.e. the tasking is complete or the order has expired), the CSP deletes the sensitive field and the salt, but keeps the hash as part of the audit record.
- In many cases, the CSP audit can be performed without knowing the value of the sensitive field (for example, if they need to check the tasking numbers, or the dates of requests, or how many there were).

If, as part of a future audit process, the CSP needs to know the sensitive field, they would ask the LEA. The LEA would send the sensitive field and the salt, so that the CSP can check the hash is correct and have confidence that the value has not been changed. The audit would be completed and then the sensitive field and salt would be deleted by the CSP.

Annex E (informative): HTTP Byte Serving (Range Requests)

This annex provides additional detail on the use of HTTP Range Requests and the benefits with respect to reliability, performance, and increased control associated with this capability.

Downloading very large binary data structures over a global network can present many logistical challenges to include bandwidth limitations, stability of the network, availability of storage on the recipient system, and physical distance between where the CSP has placed that piece of binary data and where LEA's systems are hosted.

The approaches described in clause C.1 Model A and Model B describe a single operation where LEA requests (or receives) a binaryData record via an atomic delivery action. If this delivery operation is interrupted for any reason, the entire transaction would have to be restarted from the beginning. This problem increases in severity if the file is very large (2GB+) and if interruptions are frequent. In extreme cases, this could prevent the complete binaryData record from ever being successfully transferred.

To address the scenario where datasets are very large, needs to be accessed in a non-sequential or predictable manner, or where retrieval operations are prone to interruption, the concept of Byte serving (also known as Range Requests) was introduced in HTTP v1.1 as an optionally supported capability.

Range Requests enable the client to request specific portions, or ranges, of a specified piece of binary data. A simplified sequence that illustrates how Range Requests are handled is pictured below. A full examination of the topic is out of scope of the present document.

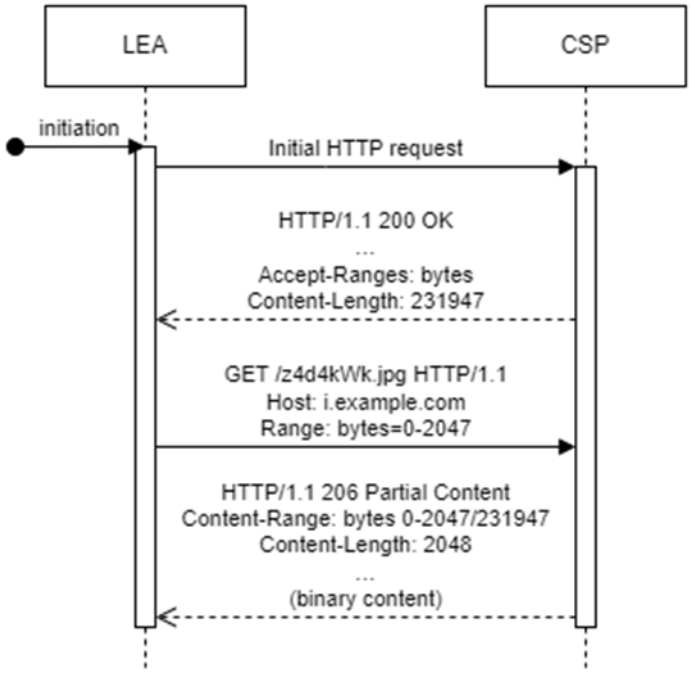


Figure E.1: High-Level Range Request

Range Requests can come from a single system (as briefly detailed in figure E.1), or they can be spread across multiple systems to enable a distributed retrieval operation that can further increase download rate.

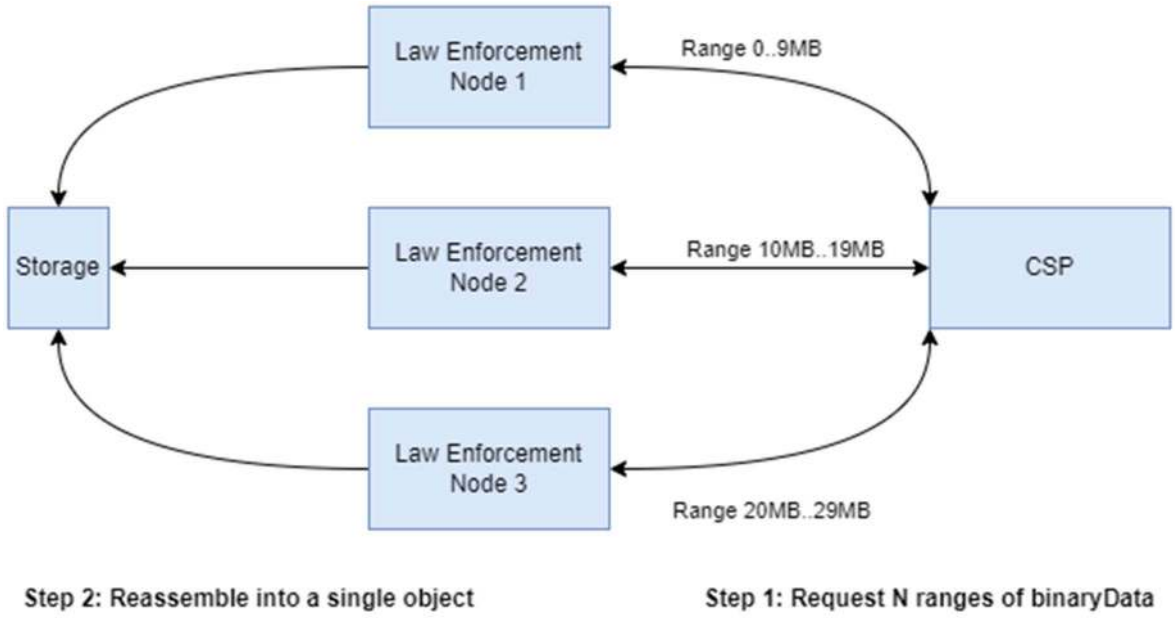


Figure E.2: Multi-node data retrieval and reassembly

Figure E.2 illustrates a 3-node configuration with a theoretical improvement of 3x when compared to a single node. Each node is tasked to retrieve a portion of the content. In this model, reassembly is coordinated across nodes to ensure they each retrieve and reassemble their portion in the correct order to reproduce the original file.

As shown in figures E.1 and E.2, the LEA can specify the range size for each request. This size is determined by the LEA and can change dynamically based on download performance or for other factors. For example, if an LEA is downloading 10 MB of content per request and one of those requests fails due to connectivity issues, the LEA could choose to repeat with another 10 MB request, or it could scale down to a smaller range per request until these connectivity issues are resolved.

Annex F (informative): Bibliography

- IETF RFC 2818: "HTTP Over TLS".

NOTE: Obsoleted by IETF RFC 9110.

- IETF RFC 7525: "Recommendations for Secure Use of Transport Layer Security (TLS) and Datagram Transport Layer Security (DTLS)".

NOTE: Obsoleted by IETF RFC 9325.

Annex G (informative): Change history

Status of Technical Specification ETSI TS 103 707 Handover for messaging services over HTTP/XML		
TC LI approval date	**Version**	**Remarks**
March 2020	1.1.1	First publication of the TS after approval by Remote Consensus following the agreements at ETSI TC LI#53 (4-6 February 2020, Sophia Antipolis, France)
February 2021	1.2.1	Included Change Requests agreed by ETSI TC LI#56e CR001, LI(21)P56019r2 (Cat B) Addition of security recommendations CR003, LI(21)P56023r4 (Cat B) Delivery of Lawful Disclosure Information
June 2021	1.3.1	Included Change Request agreed by ETSI TC LI#57e CR004r2; LI(21)P57029r2 (Cat F) Allowing multiple handover items
October 2021	1.4.1	Included Change Request agreed by ETSI TC LI#58e CR005; LI(21)P58011 (Cat B) Scope delimitation and TLS implementation recommendation in security clause
February 2022	1.5.1	Included Change Request agreed by ETSI TC LI#59e CR006; LI(22)P59011 (Cat F) Fixing inconsistency between prose and XSD
July 2022	1.6.1	Included Change Request agreed by ETSI TC LI#60 CR008; LI(22)P60020r3 (Cat F) Alignment of title and scope
December 2023	1.7.1	Included Change Request agreed by ETSI TC LI#64 CR011; LI(22)P60020r3 (Cat B) Adding a format for identifiers
February 2024	1.8.1	Included Change Request agreed by ETSI TC LI#65 CR012; LI(24)P65012r1 (Cat C) Update of obsoleted RFC references
July 2024	1.9.1	Included Change Request agreed by ETSI TC LI#66 CR013;LI(24)P66020r2 (Cat B) Addition of Model C – Range Request deliver
November 2024	1.10.1	Included Change Request agreed by ETSI TC LI#67 CR014;LI(24)P67034r3 (Cat C) Checksums

History

Document history		
V1.1.1	March 2020	Publication
V1.2.1	March 2021	Publication
V1.3.1	July 2021	Publication
V1.4.1	December 2021	Publication
V1.5.1	March 2022	Publication
V1.6.1	August 2022	Publication
V1.7.1	January 2024	Publication
V1.8.1	April 2024	Publication
V1.9.1	August 2024	Publication
V1.10.1	December 2024	Publication